

Before we begin,

The RenderMan Birthday Paradox...

For many years and many conferences RenderMan and Dan Kaminsky were frequently scheduled opposite each other. It became a running joke they never saw each others talks. Dan called it the “RenderMan Birthday Paradox”.

Dan passed away April 23rd, 2021. He was a hero and a friend to us all

This is RenderMan’s first talk without the Birthday Paradox problem and it is not easy to be up here knowing that

Please take care of yourselves and each other because if we don’t, who will?

Miss you Dan

Damned If You Do....

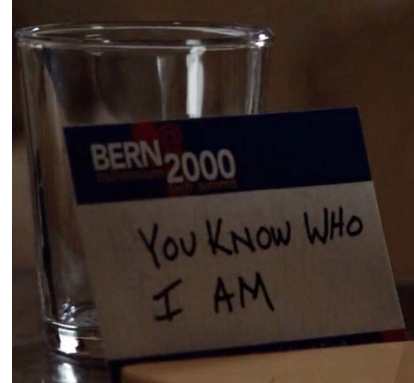
The Risks Of
Pointing Out The Emperor Is Buck Naked

The Legal Stuff

- Opinions expressed are our own
- We do not represent our employers in any way
- Please do not sue us
- Do not pet, eat or taunt the super happy fun ball

RenderMan Introduction

- You Know Who I Am...
- Every Defcon since DC7 in 1999 (excepting the plague years)
- Lost track of how many talks, panels, contests, etc
- Black Badge holder
- 3 time Hacker Jeopardy champion
- Pope of the Church of Wifi
- Hacker of Sex Toys (internetofdon.gs)
- Hero to some, annoyance to most



Thomas Introduction

- Here for the politician jokes (recovering I promise)
- Second Defcon - first post safe mode, first talk
- Security Architect for a sub-national Gov
- Once [REDACTED] a Government [REDACTED] which led to this talk
- Just here for the vibes
- Very serious picture that looks like I belong at blackhat not defcon
- I definitely don't represent my employer here - views are my own



Why Are We Here?

- “If you see something, say something” mentality post 9/11
- Hackers gonna hack, (generally) good people want to make things better
- Pointing out problems is more perilous than it should be
- Both have had run ins with these issues with our local government
- We’re Canadian (sorry) but the problem applies equally everywhere
- Learn from our mistakes and lets fix the legislation and policies so we can fix the other problems safely
- Why do I care? Let’s go back 5 years....

RenderMan's Tale

RenderMan's Tale

- Employed at ATB financial as a senior security analyst - Kinda dream job
- September 2018, B-Sides YEG; Gave a talk on why we can't have nice things
- Service Alberta acting CISO says "We scan and fix stuff all the time"
- Shodan says otherwise. Decide to add some findings to my talk last minute
- Added open printers, EoL servers, servers 10 years behind on patching
- Gave warning to GoA CISO I'd be doing this, got "blessing"
- Gave the talk (no redactions, whole other talk), sent my data to acting CISO right after, met them a week later for lunch
- All was well....

RenderMan's Tale

- ATB Financial is a crown corporation, owned by the GoA, run at arm's length, Turns out that arm is very short....
- Service Alberta “Owned” the GoA IPs but handed them out like an ISP
- Panic across the chain of command at Service Alberta and beyond
- Emails were sent, calls were made, meetings held
- Code of Conduct violation; Causing embarrassment to the organization
- October 10th, 2018 my services were no longer required at ATB

RenderMan's Tale

- A hacker with time on their hands is dangerous...
- I began to dig into the problems I had found on Shodan
- ~150 hosts, 3200 vulnerabilities later...
- F5 admin logins public facing w/flipped rule, debug interfaces, Lansweeper default install, heaps of unpatched servers and out of date/EoL software
- Documented as much as possible, w/ Shodan links and everything I could
- Ethically and morally felt I still needed to see these issues resolved
- No official reporting channels, no broad oversight, no centralization at all
- The buck (CAN\$) stops nowhere...

RenderMan's Tale

- Knocked on many doors to get attention to the matter, handed over data, little or no action
- Engaged Public interest commissioner [PIC] (oversight on fraud, waste, etc)
- Not much interest until I pointed out the 70+ vulns in their “secure reporting portal” for filing complaints
- PIC leaned on GoA to do something, and they agreed to
- Got a paper letter from deputy minister of Service Alberta telling me to report issues to the CISO office via email, which I promptly did (Feb 2019)
- And waited.....

RenderMan's Tale

- Publicly available policy (likely not meant to be public) stated criticals were to be fixed in 30 days...
- 21 days later, just before an election, nothing had happened
- I messaged Service Alberta that after 30 days I had no moral or ethical issues going public with my findings
- Another questionable moment of judgement on my part, best discussed later, because....

They Called The Cops On Me....

RenderMan's Tale

- City police computer crime investigators called me to “Chat” about “Threats”
- Met in a public coffee shop downtown (public, cameras, coffee)
- Walked them through everything (they learned a bunch of stuff that day)
- GoA never told them it was policy to fix things in 30 days
- Thanked me at the end for trying to protect Albertan's information (theirs too)
- Told them to have GoA call me and talk to me so we could sort this all out

RenderMan's Tale

- 2 days later, met with CISO of Service Alberta
- Turns out he called the cops on me on lawyers advice
- Good man, tough position, short on resources and political capital
- Explained a lot of the systemic problems and the structure of GoA IT
- Hatchet is buried now (not in anyone's head)
- I'd rather be part of the solution, so better to play nice, though I have continued to be a pain in the ass where appropriate

RenderMan's Tale

- Many things (besides my choices) caused my problems
- Lack of a vulnerability disclosure program, guidance, policy or official channels
- No whistleblower or safe harbor protection for public or even employees of other departments (or crown corporations)
- Anecdotal evidence (and some documentation) of ass covering within various departments leading to...
- Exaggerated and untrue claims about breaching confidentiality or using privileged info used as justification for termination
- It's behind me now, I've moved on with life (mostly)
- Fast forward to...

The Mississippi Case

The Mississippi Case

- October 2021
- St. Louis Post-Dispatch journalist Josh Renaud reports that teacher SSN's were publicly available in the HTML source on a government licensing lookup website
- Confirmed with a compsci professor, reported to the state, delayed publication until it was fixed
- Department of education drafted a statement commending him
- All well and good, right?
- Then Governor Mike Parson stepped in....

The Mississippi Case

- Governor Parson claimed the reporter was a “hacker” who was “acting against a state agency to compromise teachers’ personal information in an attempt to embarrass the state and sell headlines to their news outlet”
- The “hack” was pressing F12 and viewing source, SSN’s were in the response of any query
- Case referred for prosecutors office for investigation
- 5 months later, no charges, no crime found
- Turns out the Governor's office was responsible for the website in question
- Funny on the surface to us, but 5 months of hell for something literally anyone could do?

The Mississippi Case

- Legal grey areas, misunderstanding, knee-jerk reactions, political BS all contributed
- Lack of documented process and procedures for vulnerability reports
- CFAA says accessing information without authorization is a crime. But what if that information is already publicly available in HTML source?
- Many orgs assume the worst when receiving a report and call the lawyers first before anyone technical
- Add politicians to the mix who don't understand technology and things get really bad
- Which leads to my case...

The Thomas Dang Affair

The Thomas Dang Affair

- September 2021 (year 345 of the pandemic)
- Vaccines have been rolling out but still not out of the woods yet
- Alberta Premier Jason Kenney declared “The Best Summer Ever” and rolled back all COVID restrictions
- By September, things were worse than ever
- Premier Kenney had stated there would never be vaccine passports....
- “Restrictions exemption program”
- Everyone needed proof of vaccination ASAP, online health records slammed
- A portal to retrieve COVID vaccinations was built very quickly
- Initial site left much to be desired

The Thomas Dang Affair

- Site required Alberta Healthcare Number, DOB, and month/year of a vaccination dose
- Original site spat out an unlocked, unsigned PDF with no QR code that was editable by anyone *facepalm*
- Looking deeper, there was room for enumeration as DOB and dose dates were common knowledge, only Alberta Health Number was unique
- AHN has a check-digit formula so the space is relatively small
- Received concerns from an Albertan that brute force enumeration might be possible
- Decided to check it out myself

The Thomas Dang Affair

- Very simple python script (I think I described it as highschool level to the cops), but there was IP based rate limiting, but no CAPTCHA or other controls
- Solution: Pipe it through TOR
- Used Premier Kenney's DOB (public record) and vaccination date (social media)
- Many requests later, got a hit. Wasn't him, but point proven
- Reported to staff and had them seek out who to report to
- Changes quietly made without acknowledgement, CAPTCHA added about a week later
- Things seemed fine...

The Thomas Dang Affair

- December 2021 - I'm away on a ski trip and my sister is isolating on arrival from England
- RCMP decide to obtain a search warrant and raid my home - authorized to seize all computer and electronic devices



The Thomas Dang Affair

- Investigation under the health information act section 107(2(b))
- “No person shall knowingly...gain or attempt to gain access to health information in contravention of this Act”
- No wiggle room for research or public interest in securing records



The Thomas Dang Affair

- Interestingly section 107(1.1(a)) says “No custodian or affiliate of a custodian shall knowingly ... fail to take reasonable steps in accordance with the regulations to maintain administrative, technical and physical safeguards that will protect against any reasonably anticipated threat or hazard to the security or integrity of health information or of loss of health information”
- Concluded November 2022 with no criminal charges, and \$7500 (CAD) fine for breach of HIA
- Stepped down from caucus, did not seek re-election in May 2023

The Problems

The Problems Reporting to Government...

- Governments advocating for reporting by the public of risks on one hand, saying “but not this, or this, or this” on the other
- Lack of proactive planning for when, not if, someone finds a vulnerability
- Lack of vulnerability disclosure pathways with clear safe harbor provisions
- Chilling effect from laws that have no exceptions or carve outs
- Lack of general whistleblower protections for the public against Government
- Lack of oversight and accountability of many Government IT systems
- Lack of researchers understanding the law and where the landmines are
- Changes in leadership and direction are frequent and disruptive to projects and institutional knowledge

The Problems Reporting to Companies...

- No VDP means no rules, total grey area about what's "safe"
- "More lawyers than brains"
- The 5 motivations of security researchers not understood well by business
- Some industries are genuinely naive, others really should know better

I Am The Cavalry

Five Motivations of
Security Researchers

<https://iamthecavalry.org/motivations>



Protect



Puzzle



Pride/Prestige



Profit/Payment



Protest/Patriot

The Problems With Researchers...

- Ego and bravado are dangerous
- Lack of transparency by gov/orgs mean unintentional line crossing (i.e. third party hosted applications)
- Poor choices in wording can trigger legal responses (i.e. 4 Malta students case) regarding bug bounty, payment, public disclosure, etc
- Desire for recognition, publicity (ego)
- Poor understanding of the laws (i.e. health data landmines)
- Lack of empathy for orgs that are genuinely naive or under resourced
- Reliance on deadlines and inflexible processes (cookie cutter approach) leaving no nuance or understanding of orgs side of things to investigate and handle the report

Some Are Getting It...

- DOJ Announced May, 2022 a policy to not charge good faith researchers under the CFAA (does not affect State level charges)
- CISA vulnerability disclosure template
- US-CERT Guide to Coordinated Vulnerability Disclosure
- Many orgs with VDP's and safe harbors
- I Am The Cavalry's work in specific industries
- Security.txt
- Amit Elazari's work on safe harbor

<https://www.justice.gov/opa/pr/departments-justice-announces-new-policy-charging-cases-under-computer-fraud-and-abuse-act>

<https://www.cisa.gov/vulnerability-disclosure-policy-template>

<https://iamthecavalry.org>

<https://vuls.cert.org/confluence/display/CVD>

<https://securitytxt.org/>

What Is Needed From Government...

- A clear reporting path at all levels (security.txt is awesome for this)
- A VDP that spells out the rules of engagement (where is the line?),
- Clear ownership of Government systems and who to report issues to (security.txt!)
- Legislative changes to “all or nothing” laws to allow research or even accidental access to be disclosed through VDP without fear of prosecution (i.e. HIA)
- Law enforcement policy changes recognizing researchers, positive intent, greater good (See: DoJ memo)
- Policies and procedures established and public to prevent knee jerk reactions
- Consider Canary records or test systems (much like a CTF flag)
- Consider friendly “heads up” system for researchers to identify themselves before doing research (“here’s your unique header to include”)

What Is Needed From Companies/Orgs

- People want to do free work for you - LET THEM!!!
- Expect reports to come in regardless, be prepared, assume positive intent
- A VDP isn't a bug bounty, no rewards need be given, costs next to nothing (consider kudos or other non-monetary recognition)
- VDP allows for legal lines and rules of engagement (i.e. third parties, types of attacks, rate limits, etc), helps your case if claiming attack
- OSSF Vulnerability disclosure working group
- Outsource if you want (hackerone, etc)
- Reputation damage from being a complete dick is often worse than actually dealing with the report

What Is Needed From Researchers...

- Researchers are part of the problem and need to adapt and meet in the middle
- Choose your targets carefully, Be aware of radioactive data types in systems like health information
- Minimize impacts, rate limit, be reasonable, minimal PoC
- Get legal counsel on retainer; “Talk to my lawyer” stops awkward conversations
- If a known exploit, provide evidence of vulnerability, but don’t exploit it
- Watch your language. Absolutely no threats or demands of any kind
- Don’t ask for anything at all. Money, product, even public kudos
- Document the hell out of everything. Expect that you’ll wind up in court some day
- Be formal in your communication, it may become public
- Keep ego in check, pick your battles
- Consider this a call to arms to start advocating for these programs, legislation and changes

Our Model

- Governments of all levels establish a VDP for all their systems with clear rules of engagement and contact info as well as the responsible owner
- Government establishes a legal safe harbor provision for researchers who adhere to the VDP rules of engagement and report through it (notwithstanding clauses)
- Law enforcement adopts a policy of not prosecuting good-faith researchers
- Companies with VDP's explicitly state they will not press charges against good faith reports
- Government extends whistleblower protections to all government employees who report on issues in other departments
- Where possible, make public the security standards for all Government systems
- Trying to get to talk to Amit Elazari this weekend about safe harbor
- Still a work in progress, but take it and run with it...

Epilogue

Epilogue...

- Covid vaccine records website eventually added a captcha, and secured QR code, still not great, but it was enough to get through
- Alberta now has a cyber security community of interest to voice concerns and engage with GoA security leads, stakeholders
- Alberta has a nascent reporting method, still needs work
- Working in Alberta with current MLA's on these changes in Alberta (election left ambiguity about who representatives were till recently)
- Hoping to engage federally about law enforcement policy changes (RCMP)
- Hoping to engage at a federal level about similar programs and changes

Epilogue...

- Much has improved since 2018. I scared them enough to open wallets
- Threat intel team was massively shaken up
- Major re-org and efforts to provide resources to departments with issues
- Attend and contribute to the community of interest
- Took a year to see major improvement, but has been impressive since and I am far less embarrassed of the GoA's security
- Connected with Thomas when things hit the fan for him
- Wrote a letter to the editor and to the court on Thomas Dang's behalf
- While Thomas was still an MLA he saw the opportunity for a glorious bit of trolling...

It's Not Rock, It's Medal

- 2022 was Queen Elizabeth II Jubilee anniversary (70 years)
- Provinces commissioned awards for citizens for service, including Alberta
- 7000 made
- MLA's, mayors, everyone in authority got one automatically
- MLA's could nominate citizens for exemplary acts of service to the province...



You See Where This Is Going....

Sweet Satisfaction

- Nominated RenderMan for his work in 2018/19 and beyond to find and report vulnerabilities
- Initially dismissed nomination as spam
- Awarded the Queen's Platinum Jubilee medal in a ceremony on Jan 25th, 2023
- The same Government that no longer required his services has now honored his service
- One of his invited guests was the CISO of Service Alberta, the man who called the cops on him
- He was out of town giving a speech, but he recognized the humor in all this
- EvilMog also awarded a medal, so CoWF has two medal recipients in its ranks



You Get A Medal, And You Get A Medal

- Since medals for service were being given out like kindergarten gold stars, why not continue to do so?
- The CoWF Defcon medal of service, awarded to those who provide service to others in the community at Defcon
- Made by RenderMan on his Carvera CnC
- ~200 made, will be given out to those we see sharing knowledge, providing help to others, fun shenanigans, or just doing something awesome (or just bribe us with drinks or whatever, either way)
- Outline: Honoring new service to the community
- Solid: Honoring past and significant service to the community (staff, major organizers)

Medals Prototypes (Still working on them at slide deadline time)



Questions?

Render@renderlab.net
thomas@thomasdang.ca